

# Lecture 1

## 1 Introduction

### Problem Definition – Why Security?

- Decreasing scale level needed for exploits → الهجمات أصبحت أسهل.
- Evolution of technology focused on ease of use → التقدم التكنولوجي جعل الأنظمة أسهل لكن أقل أمان.
- Increased network environment and applications → زيادة استخدام الشبكات والتطبيقات.
- Moving the ball towards ease of use often reduces security → سهولة الاستخدام تقلل الأمان.

### Background:

- Security requirements have evolved.
- Traditionally provided via physical & administrative controls.
- Computer & network use requires automated tools for protection.
- Measures needed to protect data during transmission.

---

## 2 Definitions

| Term                     | Meaning                                                                                                 | بالعربي                                                     |
|--------------------------|---------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|
| <b>Computer Security</b> | Measures ensuring <b>confidentiality, integrity, availability</b> of assets (hardware, software, info). | أمان الحاسب: حماية البيانات والأجهزة من التهديدات والهجمات. |
| <b>Network Security</b>  | Measures protecting data during network transmission.                                                   | حماية البيانات أثناء نقلها عبر الشبكة.                      |
| <b>Internet Security</b> | Measures protecting data over interconnected networks, deter, prevent, detect, correct violations.      | حماية البيانات على الإنترنت من الهجمات والاختراقات.         |
| Compromise the security  |                                                                                                         |                                                             |

---

## 3 Security Attacks

### Components:

- Threat:** Potential security violation → تهديد محتمل.
- Vulnerability:** Weakness / design flaw → ضعف في النظام يمكن استغلاله.
- Attack:** Action violating security → هجوم على النظام.

### Types of Attacks:

#### A. Passive Attacks

- Monitoring transmissions without affecting resources.
- Examples: Interception, Traffic Analysis.
- Goal: Breach confidentiality (secrecy). خرق السرية.

## B. Active Attacks

- Alter or disrupt system resources.
  - Examples:
    1. **Interruption (Availability attack)** → e.g., cutting communication line.
    2. **Modification (Integrity attack)** → e.g., changing data.
    3. **Fabrication (Authenticity attack)** → e.g., inserting false messages.
  - Affect **Integrity, Availability, Authenticity**.
- 

## 4 Importance of Standards

- Standards ensure **consistency, reliability, interoperability** **قابلية التشغيل البيني** in security.
- Key Organizations:
  - **NIST (USA)** → FIPS, SP 800-series.
  - **ISOC / IETF** → Internet standards, RFCs (e.g., RFC 8446 → TLS 1.3).
  - **ITU-T** → Telecom standards (e.g., X.509 PKI).
  - **ISO** → ISO/IEC 27001 for ISMS.

**Use:** Ensures global trust and compatibility in security technologies.

---

## 5 Security Architecture – ITU-T X.800

- Framework for defining/providing security requirements for OSI systems.
  - Provides **systematic, conceptual overview** **نظرة عامة مفاهيمية** of security services and mechanisms.
- 

**6 Security Services (X.800): A service that enhances the security of data processing systems and information transfers. A security service makes use of one or more security mechanisms.**

| Service                | Purpose                       | بالعربي                   |
|------------------------|-------------------------------|---------------------------|
| <b>Authentication</b>  | Verify identity               | التأكد من الهوية          |
| <b>Access Control</b>  | Prevent unauthorized use      | منع الوصول غير المصرح     |
| <b>Confidentiality</b> | Protect data from disclosure  | حماية البيانات من الاطلاع |
| <b>Integrity</b>       | Ensure data not altered       | ضمان سلامة البيانات       |
| <b>Non-repudiation</b> | Prevent denial of action      | منع إنكار تنفيذ العمليات  |
| <b>Availability</b>    | System accessible when needed | التوافر المستمر للنظام    |

**CIA Triad:** Confidentiality, Integrity, Availability.

---

## 7 Security Mechanisms

- Detect, prevent, or recover from attacks.
- **Specific Mechanisms:** Encryption, Digital Signatures, Access Control, Notarization.
- **Pervasive Mechanisms:** Trusted Functions, Security Labels, Audit Trails, Security Recovery.
- Cryptography is fundamental.

**Physical / Software / Hardware controls:** Smartcards, database access restrictions, software security.

---

## 8 Network Security Model

- Design secure algorithms for transformation.
  - Generate secret keys & distribute securely.
  - Define protocol for safe use of keys and transformations.
- 

## 9 Network Access Security Model

### Principles for Secure Design:

| #  | Principle                               | Key Idea                                               | بالعربي                                   |
|----|-----------------------------------------|--------------------------------------------------------|-------------------------------------------|
| 1  | Economy of Mechanism                    | Keep design simple and small.                          | البساطة تقلل الأخطاء وتعزز الأمان         |
| 2  | Fail-safe Defaults                      | Deny access by default.                                | الافتراضي يكون الرفض                      |
| 3  | Complete Mediation(resource-intensive.) | Check every access request.                            | تحقق من كل محاولة وصول                    |
| 4  | Open Design                             | Security relies on secret keys, not algorithms.        | الأمان في المفاتيح وليس الخوارزمية        |
| 5  | Separation of Privilege                 | Require multiple factors, divide program by privilege. | وتقسيم العمليات حسب MFA استخدام الصلاحيات |
| 6  | Least Privilege                         | Minimum permissions for tasks.                         | أقل صلاحيات ممكنة                         |
| 7  | Least Common Mechanism                  | Reduce shared resources.                               | تقليل الموارد المشتركة                    |
| 8  | Psychological Acceptability             | Easy and user-friendly security.                       | أمان سهل للمستخدم                         |
| 9  | Isolation                               | Separate critical systems & users.                     | فصل الأنظمة الحساسة عن العامة             |
| 10 | Encapsulation                           | Access only via designated methods.                    | الوصول فقط عبر طرق محددة                  |
| 11 | Modularity                              | Split system into independent modules.                 | تقسيم النظام لوحدات مستقلة                |
| 12 | Layering (Defense in Depth)             | Multiple layers of protection.                         | طبقات حماية متعددة                        |
| 13 | Least Astonishment                      | System behaves as users expect.                        | النظام يتصرف بشكل منطقي للمستخدم          |

# Lecture 2

## 1. Importance of Cybersecurity

Cybersecurity protects all types of data — personal, financial, medical, and government — from theft and damage.

◆ **Arabic:** الأمن السيبراني مهم لأنه يحمي كل أنواع البيانات من السرقة أو التدمير.

---

## 2. Cyber Awareness

- Cybercrime is increasing globally.
- Awareness helps people recognize threats.
- Reporting cyber incidents is essential.
- Governments promote security programs like *Cyber Essentials*.

◆ **Arabic:** الوعي السيبراني ضروري لأن الجرائم الإلكترونية تزداد، ولا يمكن للشرطة التعامل معها وحدها.

---

## 3. Challenges of Cybersecurity

Organizations must protect every layer of their systems:

1. **Network security** – حماية الشبكة من الهجمات.
2. **Application security** – تأمين التطبيقات.
3. **Endpoint security** – تأمين الأجهزة المتصلة بالشبكة.
4. **Data security** – حماية بيانات الشركة والمستخدمين.
5. **Identity management** – التحكم في صلاحيات المستخدمين.
6. **Cloud security** – حماية البيانات في السحابة.
7. **Mobile security** – تأمين الهواتف والأجهزة المحمولة.
8. **Disaster recovery** – خطة استعادة النظام بعد الكوارث.
9. **User education** – تدريب المستخدمين على الأمان.

◆ **Main Challenge:** Cyber threats keep evolving faster than defenses.

**Arabic:** أكبر تحدي هو أن التهديدات تتطور بسرعة كبيرة جدًا.

---

## 4. Cyberspace

Cyberspace includes everything connected digitally — hardware, software, data, people, and networks.

◆ **Arabic:** الفضاء السيبراني هو البيئة الرقمية التي تجمع الأجهزة، البرمجيات، البيانات، والبشر.

---

## 5. Cyber Threats

A cyber threat is a **malicious** act that steals, damages, or disrupts digital data or systems.

◆ **Arabic:** التهديد السيبراني هو أي عمل خبيث يهدف لتدمير أو سرقة أو تعطيل البيانات.

---

## 6. Types of Cybersecurity Threats

### Common threats include:

- **Malware** – Malicious software designed to damage systems, disrupt operations, or steal data.
- **Spyware** – A type of malware that secretly collects user data and sends it to an attacker.
- **Phishing** – **Fraudulent** messages or emails used to trick individuals into giving passwords, financial details, or personal data.
- **DDoS Attacks** – Flooding a network or website with traffic to make it unavailable to users.
- **Ransomware** – Malware that encrypts files and requires payment (ransom) to restore access.
- **Zero-Day Exploits** – Attacks targeting security vulnerabilities that are unknown to the vendor and not yet patched.
- **Trojans** – Malicious programs **disguised** as **legitimate** software, creating a backdoor for attackers to access systems.
- **Wiper Attacks** – Attacks designed to permanently delete or wipe data from a system.
- **MITM (Man-in-the-Middle)** – Intercepting and possibly altering communication between two parties without their knowledge.
- **SQL Injection** – Injecting malicious SQL code into database queries to access or manipulate data illegally.
- **Password Attacks** – Attempting to steal or crack passwords using methods like brute force, dictionary attacks, or credential theft.
- **Advanced Persistent Threats (APT)** – Long-term targeted attacks where hackers gain and maintain undetected access to a network to steal data over time.
- **Drive-By Downloads** – Automatic download of malicious software simply by visiting a compromised website.
- **Malvertising** – Using online advertisements to spread malware, often through legitimate ad networks.
- **Rogue Software** – Fake security or utility software that tricks users into installing it, then exploits their system.
- **Unpatched Software** – Software that has known vulnerabilities because users or organizations have not installed security updates.
- **Data Manipulation Attacks** – Altering data to disrupt business processes or create mistrust in information systems.
- **Data Theft / Intellectual Property Theft** – Unauthorized copying or stealing of confidential business data or creative assets.
- **Data Destruction** – Intentionally deleting data to cause damage or disrupt business operations.

- **Theft of Money** – Cybercriminal attacks targeting bank accounts, credit card details, or online payment systems to steal money.

◆ **Arabic:** هذه أشهر أنواع الهجمات الإلكترونية التي تواجه الأنظمة الحديثة.

---

## 7. Cyber Warfare

Cyber warfare = cyber attacks between countries to cause harm.

**Types:**

- **Espionage** – Stealing national secrets.
- **Sabotage** – Damaging systems or data.
- **DoS attacks** – Blocking government or military websites.
- **Power Grid Attacks** – Shutting down electricity.
- **Propaganda** – Spreading false information.
- **Economic Disruption** – Harming financial systems.
- **Surprise Attacks** – Sudden massive attacks.

◆ **Arabic:** الحرب السيبرانية هي هجمات بين الدول لإحداث أضرار سياسية أو اقتصادية أو عسكرية.

---

## 8. Cyber Terrorism

**Politically motivated** cyberattacks that cause fear or violence.

◆ **Arabic:** الإرهاب السيبراني هو هجوم إلكتروني له أهداف سياسية أو دينية لنشر الخوف أو تعطيل البنية التحتية.

---

## 9. Critical Infrastructure Security

Critical infrastructure = **vital** systems like energy, water, transportation, healthcare, and defense.

If attacked, the country could face major crises.

◆ **Arabic:** البنية التحتية الحرجة هي الأنظمة الحيوية للدولة مثل الكهرباء والمياه والاتصالات.

---

## 10. Cost of Cybercrimes

Cost of detection

Cost of investigation and escalation

Cost of containment

Cost of recovery

Post response costs

Cybercrimes are **very expensive** for companies due to:

- Data loss
- Investigation and recovery

- Business disruption
  - Damage to brand reputation
  - ◆ **Arabic:** الجرائم الإلكترونية تكلف المؤسسات خسائر مالية كبيرة وأضرار في السمعة.
- 

## 11. Protecting Digital Assets (NIST & ENISA Framework)

Five key security functions:

1. **Identify** – معرفة المخاطر والأنظمة.
2. **Protect** – وضع وسائل حماية.
3. **Detect** – اكتشاف أي هجوم بسرعة.
4. **Respond** – التصرف بعد حدوث الهجوم.
5. **Recover** – استعادة الخدمات بسرعة.

◆ **Arabic:** هذه الخطوات الخمس أساسية في أي نظام حماية سيبراني.

---

## 12. Risk Management

Cybersecurity = managing and reducing cyber risks.

**Key Terms:**

- **Risk:** Probability × Impact of an event. (احتمال × نتيجة)
- **Threat:** Anything that can cause harm.
- **Asset:** Anything **valuable** (data, money, people).
- **Vulnerability:** Weakness that can be **exploited**.
- **Residual Risk:** Remaining risk after protection.
- **Inherent Risk:** Risk before taking any action.
- **Third-Party Risk:** Dangers from external partners.

◆ **Arabic:** إدارة المخاطر تعني تحديد الأخطار، وتقليلها، ومتابعتها لحماية البيانات.

---

## 13. Approaches to Cybersecurity

1. **Compliance-based:** Follows laws or standards (قائمة تحقق).
2. **Risk-based:** Focuses on actual organizational risks.
3. **Ad hoc:** Random security with no clear plan.

◆ **Arabic:** الطريقة الأفضل هي المبنية على المخاطر لأنها أكثر واقعية وفعالية.

---

## 14. Hackers and Crackers

- **Hackers:** Skilled people who test systems ethically. (White hats)

- **Crackers:** Break systems illegally to steal or destroy data. (Black hats)

◆ **Arabic:** الهاكر أخلاقي يساعد في الحماية، أما الكراكر غير أخلاقي ويسرق أو يدمر الأنظمة.

---

## 15. Types of Hackers

1. **White Hat:** Ethical, test systems legally.
2. **Black Hat:** Illegal hackers for personal gain.
3. **Grey Hat:** Mix between both, often unapproved testing.
4. **Red Hat:** Target high-security systems or governments.
5. **Blue Hat:** Test systems before release.
6. **Script Kiddies:** Use others' tools, little knowledge.
7. **Hactivists:** Hack for political or social causes.

◆ **Arabic:** تختلف أنواع الهاكر حسب نيتهم؛ بعضهم مفيد وبعضهم ضار.

---

## 16. Threat Agents

Groups that perform cyberattacks:

- **Corporations** – for business advantage.
- **Nation States** – government-level spying.
- **Hactivists** – political hackers.
- **Cyberterrorists** – use violence online.
- **Cybercriminals** – financial gain.
- **Cyberwarriors** – attack for national interests.
- **Script Kiddies & Social Hackers** – unskilled or manipulative hackers.

◆ **Arabic:** مصادر التهديد تشمل الشركات، الدول، الإرهابيين، والمخترقين لأسباب مختلفة.

# Lecture 3

## Cyber Kill Chain – Exam Summary

**1 Reconnaissance** – Gather info about the target (collect data, scan systems).

(جمع معلومات عن الهدف لتحديد الثغرات)

**2 Weaponization** – Create a malicious payload using an exploit + delivery method.

(تجهيز الهجوم بملف ضار أو فيروس)

**3 Delivery** – Send the payload to the target via email, link, USB, or website.

(توصيل الهجوم للهدف)

**4 Exploitation** – Execute the payload and exploit the vulnerability.

(تنفيذ الكود الضار واستغلال الثغرة)



**5 Installation** – Install malware to maintain access (persistence).

(تنشيط وصول دائم في النظام)

**6 Command & Control (C2)** – Create a channel to control the system remotely.

(التحكم في الجهاز عن بُعد)

**7 Actions on Objectives** – Achieve the attack's goal (data theft, ransomware, etc.).

(تنفيذ الهدف النهائي للهجوم مثل سرقة البيانات أو الفدية)

---

 **Quick Memory Tip:**

**R → W → D → E → I → C2 → A**

(Remember: Recon → Weapon → Deliver → Exploit → Install → Control → Act)

## Lecture 3

### Types of Malware

1. **Viruses** – Malicious code that attaches to files and activates when executed. It replicates, alters system settings, slows performance, and damages files. Prevention includes avoiding unknown emails, scanning storage devices, and secure browsing.
2. **Trojan Horses** – Malware **disguised** as **legitimate** software. It opens backdoors for attackers, steals user data, copies files, blocks or alters data, and reduces system performance.
3. **Worms** – Self-**replicating** malware that spreads across networks without user action. It exploits system vulnerabilities, consumes system resources, and may cause system crashes or send unauthorized emails.
4. **Spyware** – Secretly monitors user activities, collects data such as browsing habits and credentials, and may cause pop-ups and slow connections.
5. **Adware** – Forces unwanted ads and redirects users to advertising websites. Often installed with free software.
6. **Browser Hijackers** – Modify browser settings, redirect traffic, install plugins, steal information, and boost ad revenue for malicious sites.
7. **Rootkits** – Hide malware presence, gain administrator privileges, and control system functions while remaining undetected. Extremely hard to remove.
8. **Scareware** – Fake security warnings designed to trick users into installing fake antivirus or revealing personal information.
9. **Ransomware** – Encrypts files and demands payment to restore access.
10. **Keyloggers** – Record keystrokes and screen activity to steal passwords and sensitive data.
11. **Botnets** – Networks of infected devices controlled remotely to launch large-scale attacks like DDoS.

### Other Major Cyber Attacks

- **Brute Force Attacks:** Trying all possible passwords until success.
- **Buffer Overflow:** Overwriting memory with excess data to execute malicious code.

- **SQL Injection:** Injecting malicious SQL into web forms to access databases.
- **Cross-Site Scripting (XSS):** Injecting scripts into websites to steal session data or deface pages.
- **Denial-of-Service (DoS) & DDoS:** Overloading servers with traffic to shut down services.
- **Man-in-the-Middle Attack (MITM):** Intercepting communication between two parties to steal data.
- **Social Engineering:** Manipulating people to reveal information or install malware.
- **Phishing & Spear-Phishing:** Fake emails or targeted messages to steal credentials.
- **Spoofing:** Faking identities or addresses to gain illegal access.
- **Zero-Day Exploits:** Attacking unknown vulnerabilities before patches exist.

## Question Bank Answers

### 1. Define cybersecurity and explain its primary goals.

Cybersecurity is protecting systems, networks, and data from cyber attacks.

**Goals:** Confidentiality, Integrity, Availability (CIA).

### 2. What are the three key principles of CIA Triad?

- **Confidentiality** – Keep data private.
- **Integrity** – Prevent unauthorized changes.
- **Availability** – Ensure systems are accessible when needed.

### 3. Compare white-hat hackers and black-hat hackers.

- **White-hat:** Ethical hackers who test security.
- **Black-hat:** Criminal hackers who break systems illegally.

### 4. Explain the concept of social engineering with an example.

Tricking people to reveal information.

**Example:** Pretending to be IT support to get passwords.

### 5. Define malware and list its major categories.

Malware is malicious software designed to harm systems.

**Types:** Virus, Worm, Trojan, Spyware, Ransomware, Rootkit.

### 6. Differentiate between worms and viruses.

- **Virus:** Needs user action to spread (attach to files).
- **Worm:** Self-replicates across networks automatically.

### 7. Explain what a Trojan horse is in cybersecurity.

A fake or innocent-looking program that secretly gives attackers access.

### 8. Compare DoS and DDoS attacks.

- **DoS:** Single source floods a system.

- **DDoS:** Multiple machines attack at once (stronger).

### 9. Explain SQL Injection with an example.

Injecting malicious SQL into a website query to access database.

**Example:** ' OR '1'='1 to bypass login.

### 10. Define phishing and describe how it works.

Phishing is sending fake messages to steal login or financial info.

Victim clicks link → enters data → attacker gets it.

### 11. Compare: Hacker vs Cracker

- **Hacker:** Skilled person in computer security.
- **Cracker:** Breaks systems illegally for harm.

### 12. Define: Ransomware

Malware that locks/encrypts files and demands payment to unlock them.

### 13. Compare: Virus vs Worm

- **Virus:** Attaches to files, spreads when run.
- **Worm:** Spreads automatically through network.

---

## Part 2

### 14. Define: Rootkit

Malware that hides itself and gives attackers hidden control of a system.

### 16. Compare: Firewall vs Antivirus

- **Firewall:** Blocks unwanted network traffic.
- **Antivirus:** Detects and removes malware on a system.

### 17. Compare: Social Engineering vs Phishing

- **Social engineering:** Tricking humans to reveal info.
- **Phishing:** Social engineering through fake messages/emails.

### 18. Compare: Trojan Horse vs Spyware

- **Trojan:** Fake program that opens backdoor.
- **Spyware:** Secretly spies and steals information.

### 20. Define: SQL Injection

Attack where malicious SQL code is inserted to access database data.

### 21. Compare: Application Security vs Network Security

- **Application security:** Protects apps from attacks.
- **Network security:** Protects network and data flow.

### 22. Define: Brute Force Attack

Trying all possible passwords until correct one is found.

### **23. Compare: Scareware vs Ransomware**

- **Scareware:** Fake warnings to trick users.
- **Ransomware:** Locks data and demands payment.

### **24. Compare: Threat vs Vulnerability**

- **Threat:** Potential danger (attacker).
- **Vulnerability:** Weakness in system.

### **25. Define: Spoofing**

Faking identity (IP, email, etc.) to trick a system or user.